

Digital Certificates

Public Key Deception

Digital Certificates

Certificate Authorities

Public Key Infrastructures (PKIs)



Public Key Deception

- Impostor Claims to be a True Party
 - True party has a public and private key
 - Impostor also has a public and private key
- Impostor sends impostor's own public key to the verifier
 - Says, “This is the true party's public key”
 - This is the critical step in the deception



Public Key Deception

- If verifier accepts the impostor's public key as the true party's public key,
 - Impostor will be authenticated through any public key authentication method, because their private key will work
 - Impostor can also decrypt messages sent by the verifier if these messages are encrypted with the impostor's public key

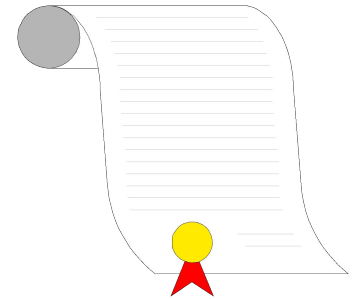


Public Key Deception

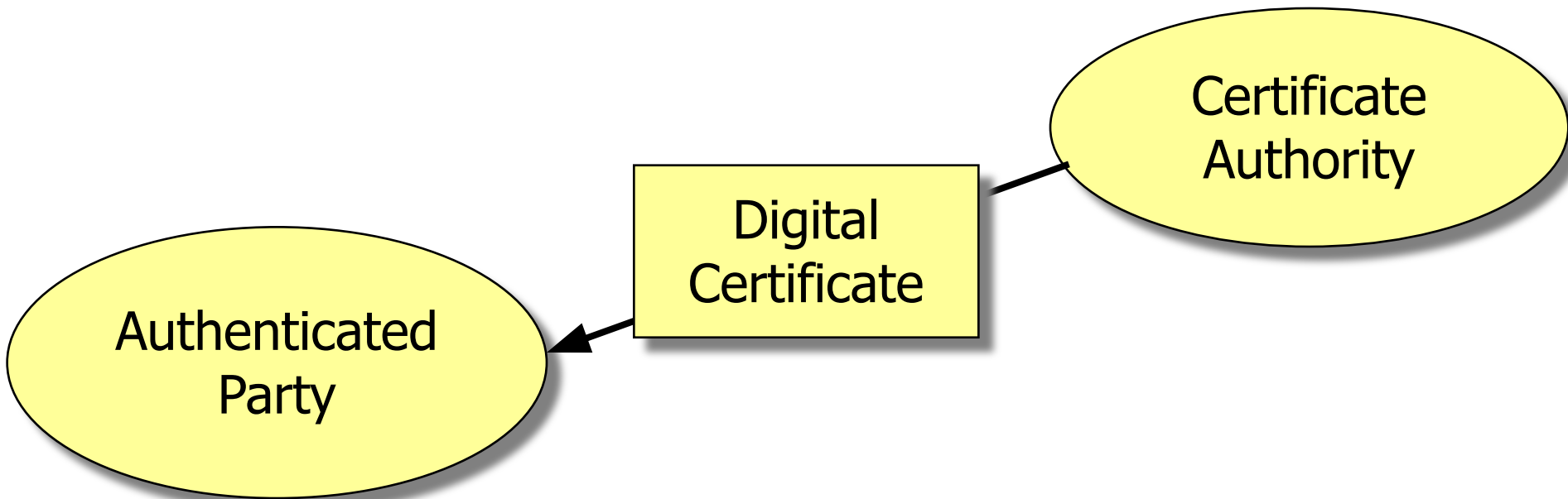
- Moral:
 - Public key encryption for privacy, confidentiality, authentication, and message integrity only works if
 - The verifier gets the true party's public key independently of the applicant,
 - From a trusted third party



Digital Certificates



- Created by a *Certificate Authority*
 - Certificate authority is the trusted third party



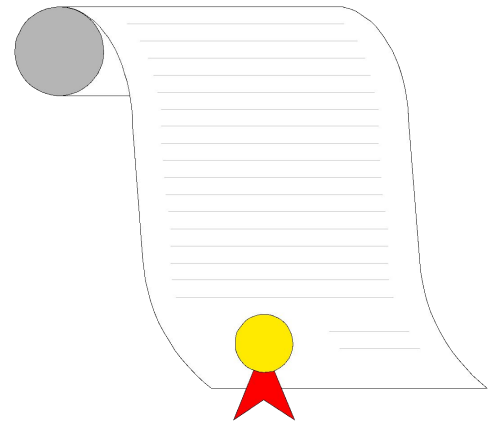
Certificate Authorities

- Unfortunately, certificate authorities are not regulated
- You must only use certificate authorities you trust
- Company can be its own certificate authority for internal authentication among its hardware and software systems



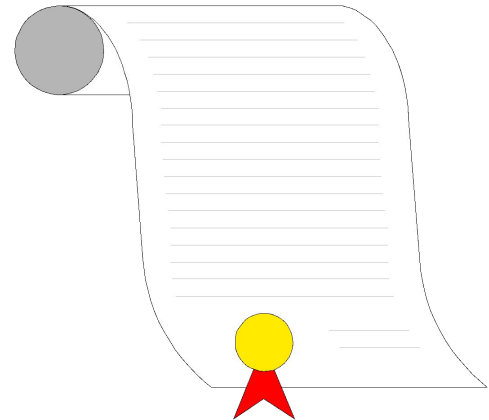
Digital Certificates

- Assert that a true party (named) has the public key contained in the digital certificate
 - Provides a name-public key pair
 - Therefore prevents public key deception
 - Fields and content are standardized by the ITU-T X.509 Standard



Digital Certificates

- Each digital certificate has its own digital signature, signed (encrypted) by the private key of the certificate authority
 - Provides message integrity so that an impostor cannot change the name field in the digital certificate to its own



Digital Certificates

- Certificate authorities may revoke digital certificates before the expiration date listed in the digital certificate
 - Revoked certificate ID numbers are placed in a *certificate revocation list (CRL)*
 - Verifier must check with the certificate authority to determine if a digital certificate is on the CRL
- Without the CRL check, digital certificates do not support authentication



Digital Certificates

- Recap
 - A digital signature gives the public key of a named party
 - This is needed for public key authentication, to prevent public key deception
 - However, a digital certificate alone does NOT provide authentication



Public Key Infrastructures (PKIs)

Private key creation and distribution

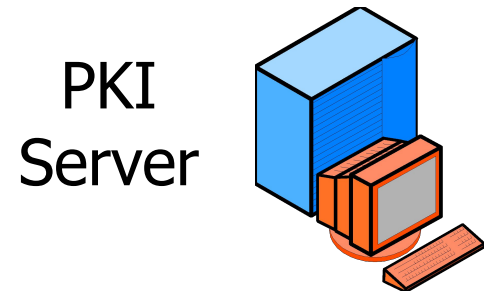
Digital certificate creation and
distribution

Certificate Revocation List checking



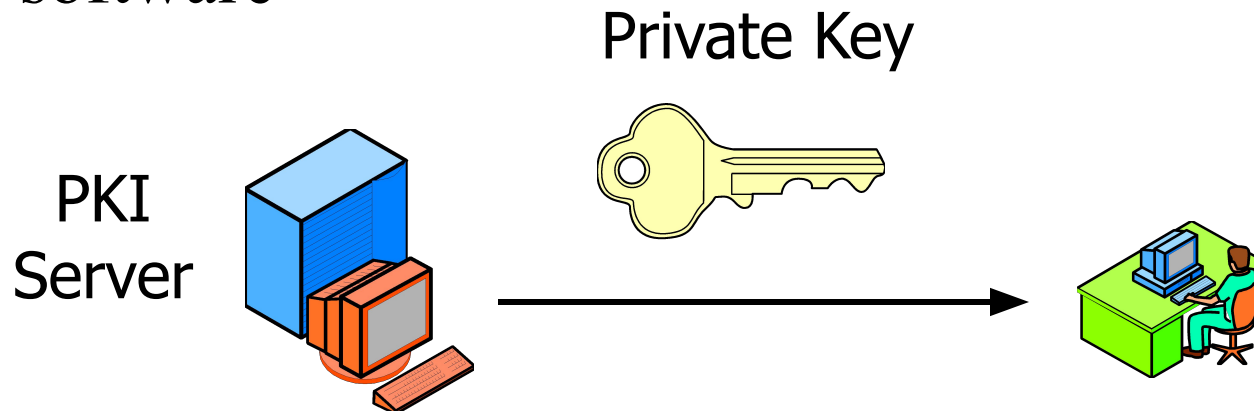
PKIs

- To use public key methods, an organization must establish a comprehensive *Public Key Infrastructure (PKI)*
 - A PKI automates most aspects of using public key encryption and authentication
 - Uses a *PKI Server*



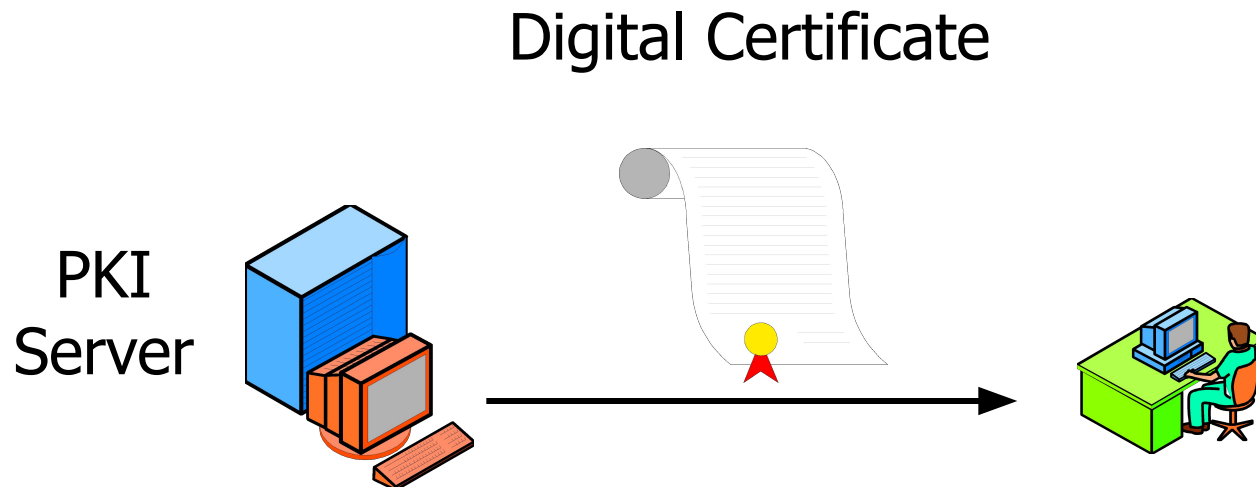
PKIs

- PKI Server Creates Public Key-Private Key Pairs
 - Distributes private keys to applicants securely
 - Often, private keys are embedded in delivered software



PKIs

- PKI Server Provides CRL Checks
 - Distributes digital certificates to verifiers
 - Checks certificate revocation list before sending digital certificates



Identity Information and
Public Key of Mario Rossi



Certificate Authority
verifies the identity of Mario Rossi
and encrypts with its Private Key



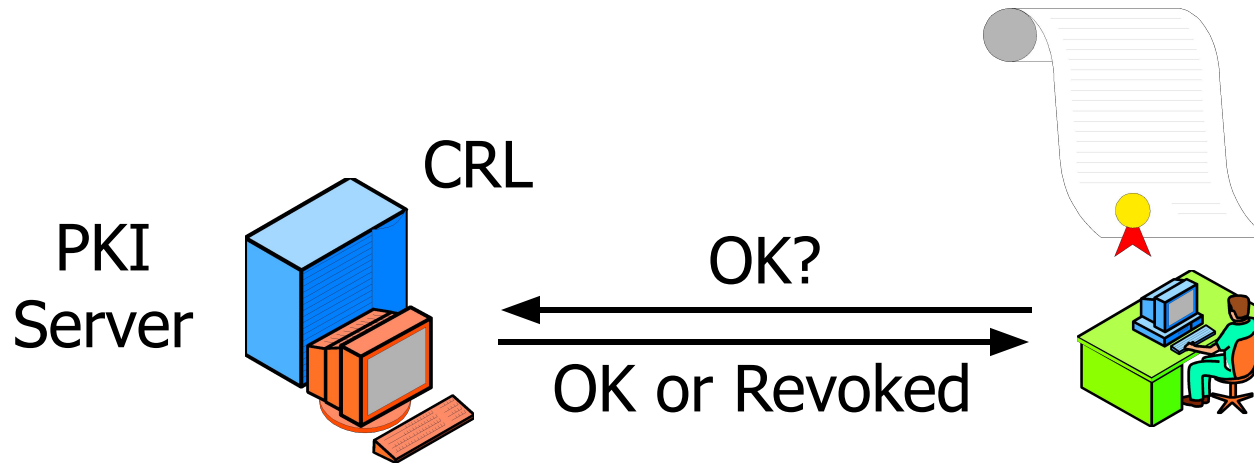
Certificate of Mario Rossi



Digitally Signed by
Certificate Authority

PKIs

- CRL Checks
 - If applicant gives verifier a digital certificate,
 - The verifier must check the certificate revocation list



Integrated Security System

- When two parties communicate ...
 - Their software usually handles the details
 - First, negotiate security methods
 - Then, authenticate one another
 - Then, exchange symmetric session key
 - Then can communicate securely using symmetric session key and message-by-message authentication



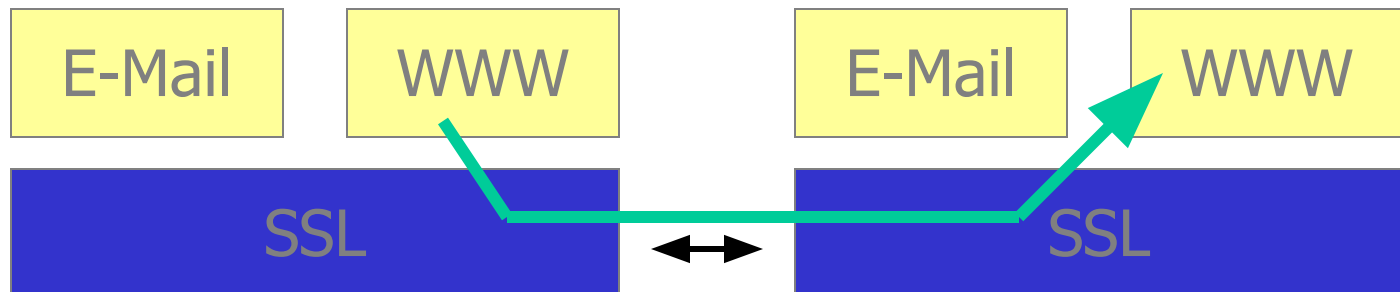
SSL Integrated Security System

- *SSL*
 - *Secure Sockets Layer*
 - Developed by Netscape
- TLS (now)
 - Netscape gave IETF control over SSL
 - IETF renamed it TLS (Transport Layer Security)
 - Usually still called SSL



Location of SSL

- Below the Application Layer
 - IETF views it at the transport layer
 - Protects all application exchanges
 - Not limited to any single application
 - WWW transactions, e-mail, etc.



SSL Operation

- Browser & Webserver Software Implement SSL
 - User can be unaware



SSL Operation

- SSL ISS Process
 - Two sides negotiate security parameters
 - Webserver authenticates itself
 - Browser may authenticate itself but rarely does
 - Browser selects a symmetric session key, sends to webserver
 - Adds a digital signature and encrypts all messages with the symmetric key



Importance of SSL

- Supported by Almost All Browsers
 - De facto standard for Internet application security
- Problems
 - Relatively weak security
 - Does not involve security on merchant server
 - Does not validate credit card numbers
 - Viewed as an available but temporary approach to consumer security



Other ISSs

- SSL is merely an example integrated security system
- Many other ISSs exist
 - IPsec PPP and PPTP Etc.



Other ISSs

- All ISSs have the same general steps
 - Negotiate security parameters
 - Authenticate the partners
 - Exchange a session key
 - Communicate with message-by-message privacy, authentication, and message integrity

